

# TAREA HE05

## Hacking de aplicativos web

**Autor:** Carlos España Del Pozo - CETI

## Contenido

|                                                                 |    |
|-----------------------------------------------------------------|----|
| Detalles de la tarea de esta unidad .....                       | 3  |
| Apartado 1: Fuerza Bruta con BurpSuite .....                    | 3  |
| Respuestas 1 .....                                              | 4  |
| Apartado 2: Cross Site Scripting Almacenado con BurpSuite ..... | 9  |
| Respuestas 2 .....                                              | 9  |
| Apartado 3: Ejecución remota de código con BurpSuite .....      | 10 |
| Respuestas 3 .....                                              | 10 |
| Apartado 4: Ejecución de inyección SQL con BurpSuite.....       | 11 |
| Respuestas 4 .....                                              | 11 |
| Apartado 5: Extraer datos con sqlmap.....                       | 13 |
| Respuestas 5 .....                                              | 13 |

## Detalles de la tarea de esta unidad

### Caso práctico

*Una vez Pedro ha completado el curso, ha adquirido los conocimientos necesarios para poder realizar tareas propias de una auditoría de hacking ético sobre un aplicativo web.*

*Al igual que hicieron sus compañeros Luis y Paloma, Pedro ha de realizar unas sesiones formativas con la finalidad de compartir estos conceptos con sus compañeros de trabajo. De esta manera, todos podrán tener, al menos, unas nociones básicas de ciertas técnicas de hacking ético en aplicativos webs que ha podido aprender Pedro en el curso.*

*Pedro tiene pensado seguir el mismo enfoque práctico que sus compañeros han dado a este tipo de sesiones formativas dado que todos tienen claro que es el mejor sistema para poder afianzar los conceptos. De modo que configura un laboratorio de pruebas específico para esta temática y resolver de manera práctica algunas de las vulnerabilidades en aplicativos web aprendidas durante el curso.*

Todos los apartados de esta práctica se realizarán sobre el portal vulnerable DVWA que se encuentra instalado en la máquina metasploitable bajo el protocolo HTTP.



Tendréis que configurar el nivel de seguridad en "low" para poder realizar la práctica. Para ello, una vez accedáis al portal tendréis que configurar el nivel de seguridad en el apartado "DVWA Security"



## Apartado 1: Fuerza Bruta con BurpSuite

Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de fuerza bruta sobre la funcionalidad "Brute Force" de Damn Vulnerable Web Application.

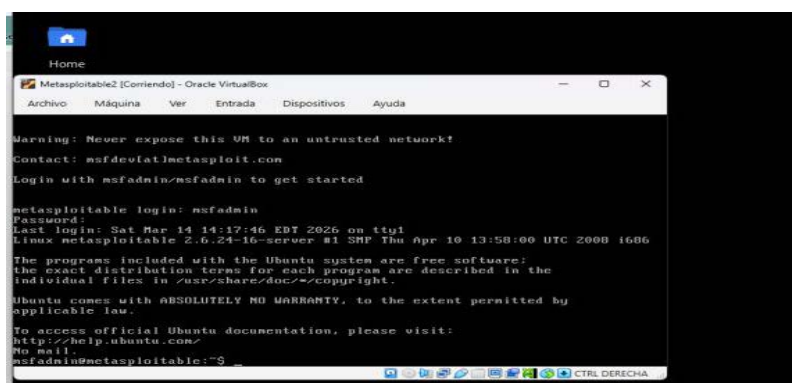
## Respuestas 1

A continuación, detallo los pasos realizados para montar el laboratorio:

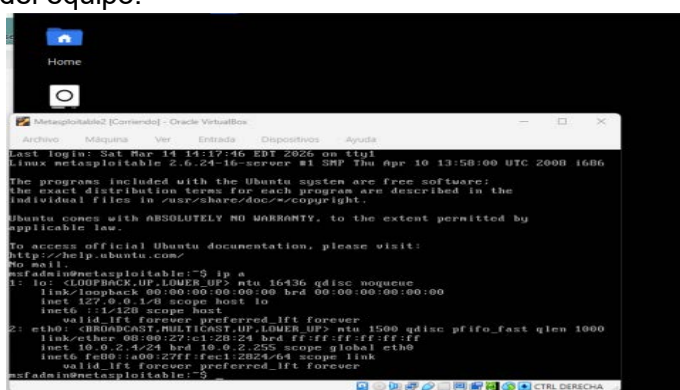
### Laboratorio:

- Sistemas operativos: **Kali Linux y Measploitable2 (x64)**
- Redes: **RedNAT**

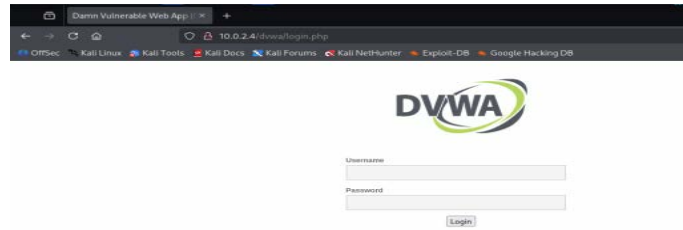
Para la realización de esta práctica se ha utilizado la máquina vulnerable **Metasploitable2**, que contiene la aplicación web **Damn Vulnerable Web Application (DVWA)** accesible mediante el protocolo HTTP.



- Revisamos la IP del equipo:



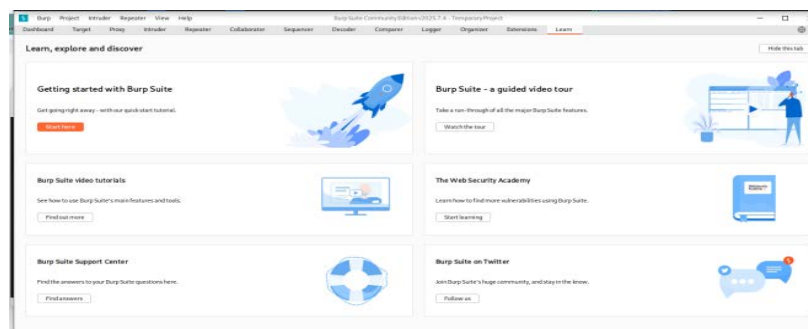
- Verificamos desde nuestro servidor Kali Linux que podemos conectar a DVWA, de la IP del server Metasploitable2:



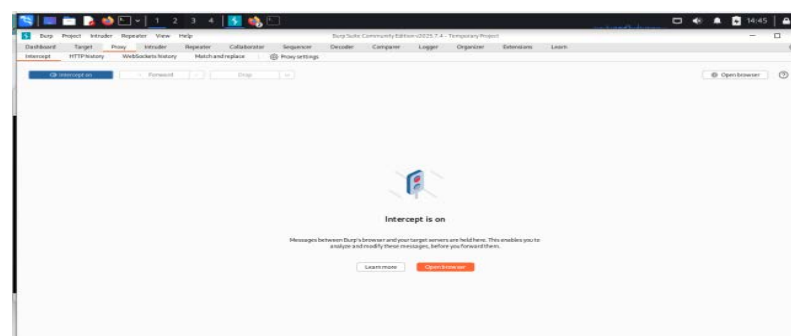
- **Fuerza Bruta**

Para realizar la tarea de realizar un ataque de **Brute Force** de DVWA, seguiremos estos pasos:

- Dentro de nuestra máquina Kaili, arrancamos el aplicativo instalado BurpSuite:



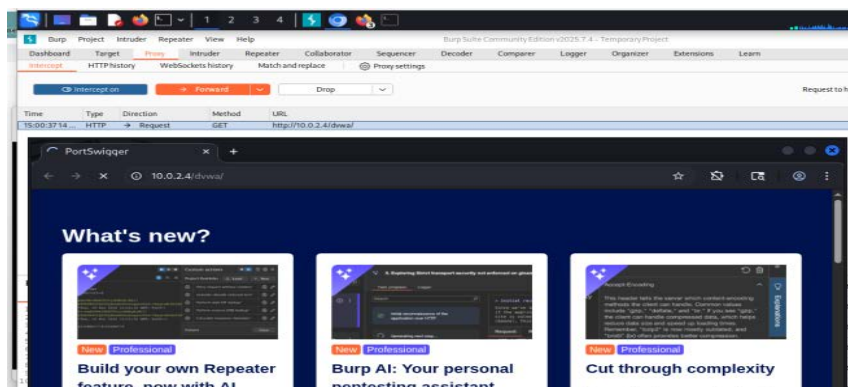
- En nuestro aplicativo BurpSuite pinchamos en Proxy -> Intercept ON



Ahora abrimos el Navegador de BurpSuite “Open browser”

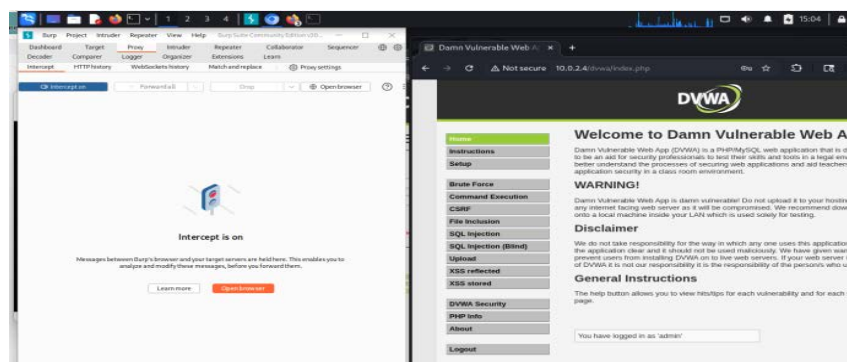
Y desde este, abrimos la web de dvwa del server **metasploitable2**:

http://10.0.2.4/dvwa/

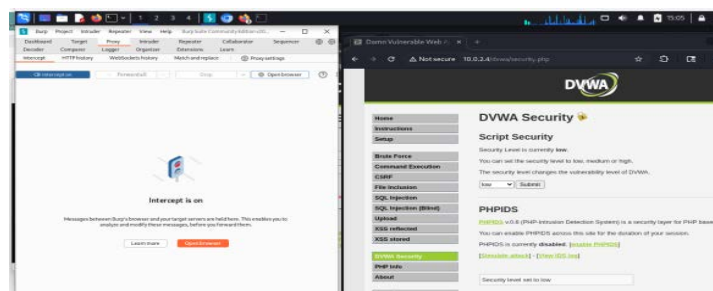


Vemos como se queda la petición interceptada y pinchamos en -> Forward para continuar

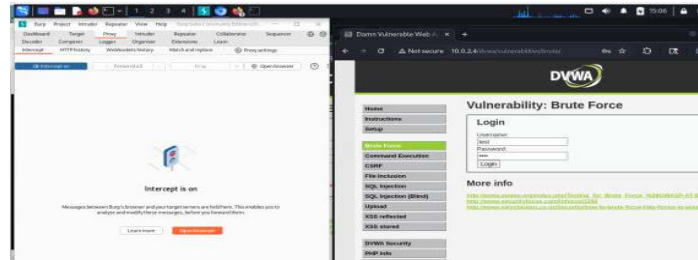
- Iniciamos sesión con las credenciales por defecto:  
 Usuario: admin  
 Contraseña: password



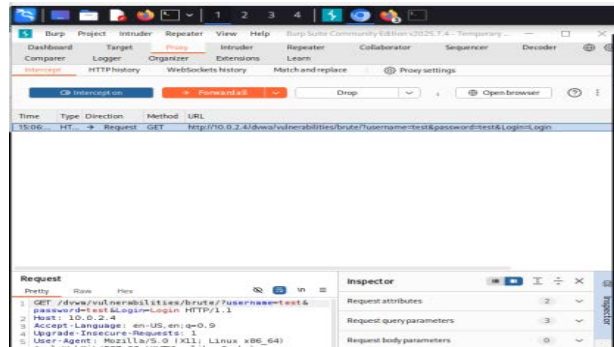
Ahora configuramos el nivel de seguridad en LOW en el apartado "DVWA Security" y pinchamos en "Submit":



- En la WEB de DVWA accedemos al apartado Brute Force y en el Login ponemos un Username y password cualquiera:

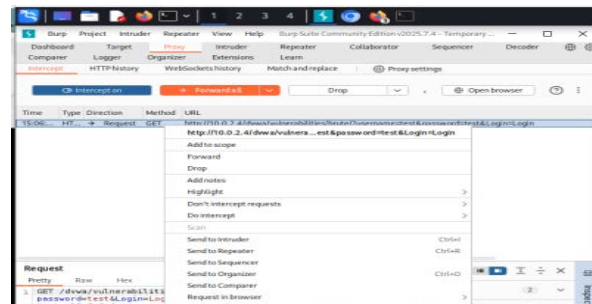


- Comprobamos que BurpSuite intercepta la petición HTTP enviada al servidor.

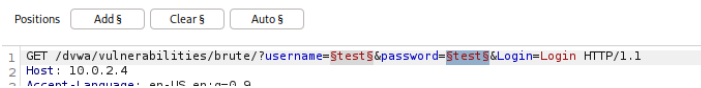


- Ahora enviaremos la petición a Intruder

Click derecho en la petición -> Send to Intruder



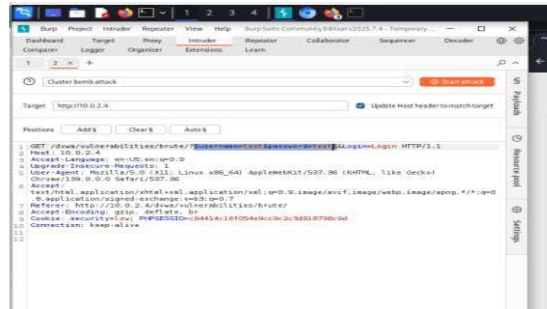
- Ahora pinchamos en la opción de Intruder
- Seleccionamos los campos “username y password” y lo añadimos como **Positions**



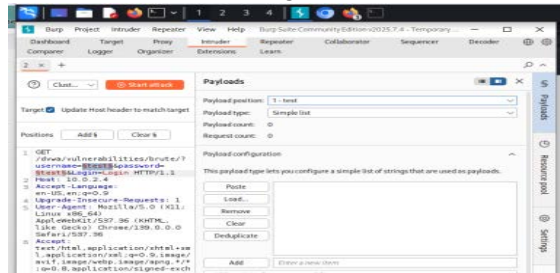
- Modificamos el tipo de ataque a -> **Cluster Bomb attack**



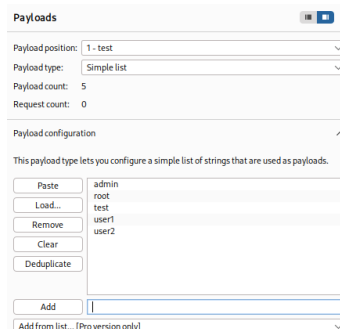




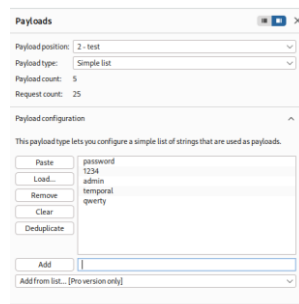
- Ahora vamos al apartado de la derecha **“Payloads”**



- Seleccionamos el primero Payload position y dentro del Payload configuration añadimos una lista de posibles **“username”**



- Ahora seleccionamos el segundo Payload position y dentro del Payload configuration añadimos una lista de posibles **“passwords”**



- Finalmente Ejecutamos el ataque pinchando en **“Start attack”**



| Request | Response 1 | Response 2 | Status code | Response received | Driver | Timeout | Length | Comment |
|---------|------------|------------|-------------|-------------------|--------|---------|--------|---------|
| 1       | admin      | password   | 200         | 20                |        |         | 4500   |         |
| 2       | test       | password   | 200         | 17                |        |         | 4500   |         |
| 3       | test       | password   | 200         | 16                |        |         | 4500   |         |
| 4       | test       | password   | 200         | 16                |        |         | 4500   |         |
| 5       | admin      | password   | 200         | 16                |        |         | 4500   |         |
| 6       | test       | password   | 200         | 16                |        |         | 4500   |         |

## Apartado 2: Cross Site Scripting Almacenado con BurpSuite

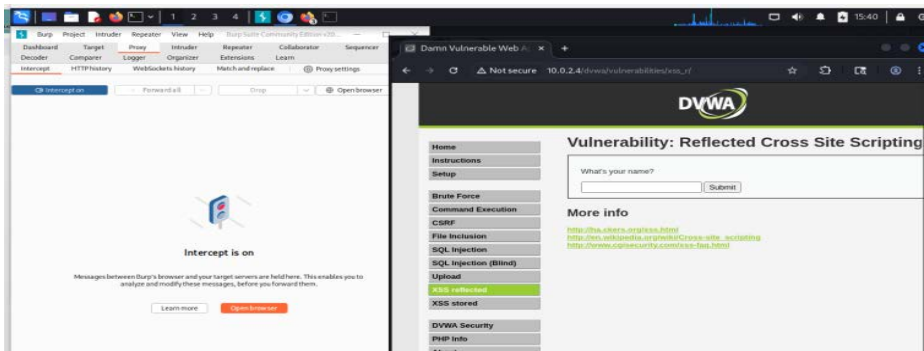
Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de Cross Site Scripting Almacenado sobre la funcionalidad "XSS stored" de Damn Vulnerable Web Application.

### Respuestas 2

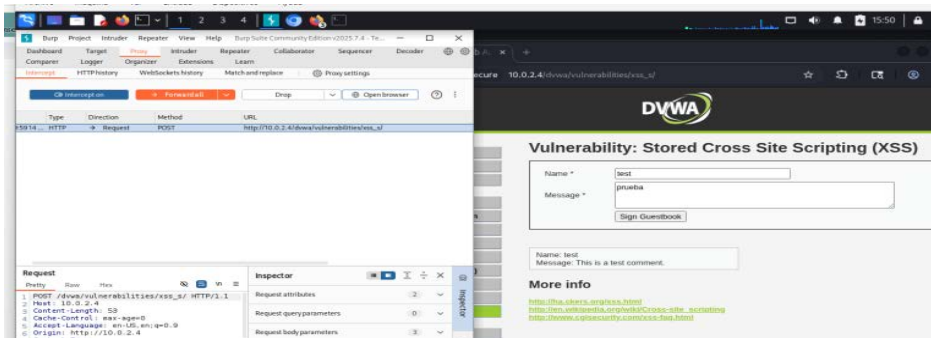
- Cross Site Scripting Almacenado**

Para realizar la tarea de realizar un ataque de Cross Site Scripting Almacenado de DVWA, seguiremos estos pasos:

- Dentro de BurpSuite, abrimos la web de **DVWA** desde el navegador



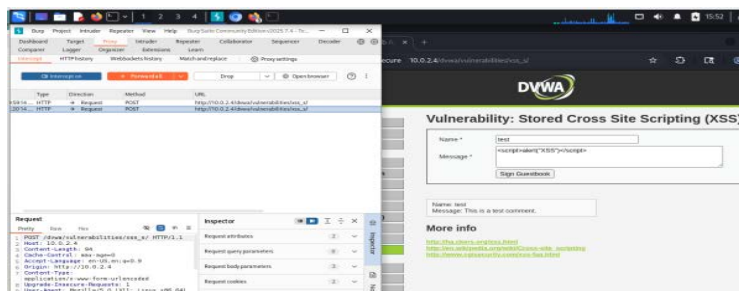
- En la WEB de DVWA accedemos al apartado **XSS stored** y realizamos un envío de prueba del formulario para verificar la interceptación.



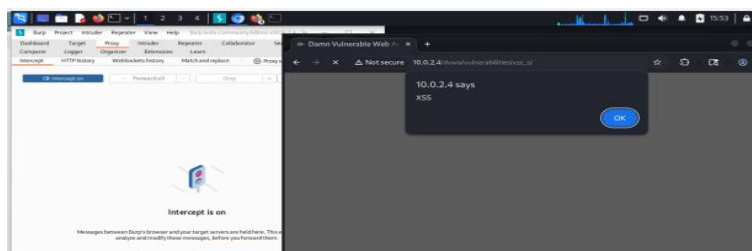
- Ahora añadimos en el campo del Mensaje el siguiente código para inyectar un script de javascript

<script>alert('XSS')</script>

- Enviamos la firma del libro de visitas



- Comprobamos que, al cargar la página, se vuelve a cargar el script



## Apartado 3: Ejecución remota de código con BurpSuite

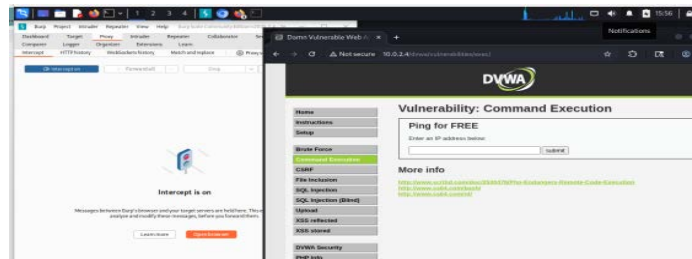
Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de ejecución remota de código sobre la funcionalidad "Command Execution" de Damn Vulnerable Web Application.

## Respuestas 3

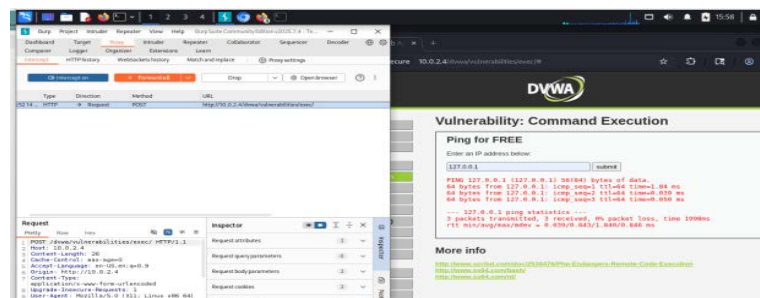
### • Command Execution

Para realizar la tarea de realizar un ataque de Command Execution de DVWA, seguiremos estos pasos:

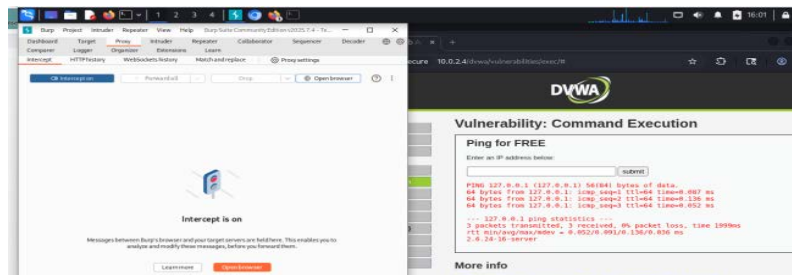
- Dentro de BurpSuite, abrimos la web de **DVWA** desde el navegador



- En la WEB de DVWA accedemos al apartado **Command Execution** y realizamos un envío de prueba a localhost para verificar la interceptación.



- Modificamos el parámetro para que añada un comando del sistema, como un `uname -r`



- Comprobamos que nos devuelve el resultado y es vulnerable

## Apartado 4: Ejecución de inyección SQL con BurpSuite

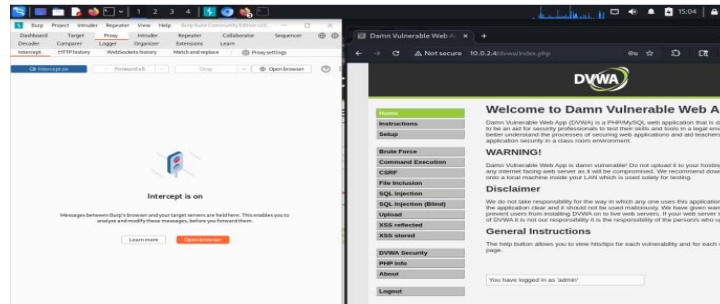
Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de inyección SQL sobre la funcionalidad "SQL injection" de Damn Vulnerable Web Application.

## Respuestas 4

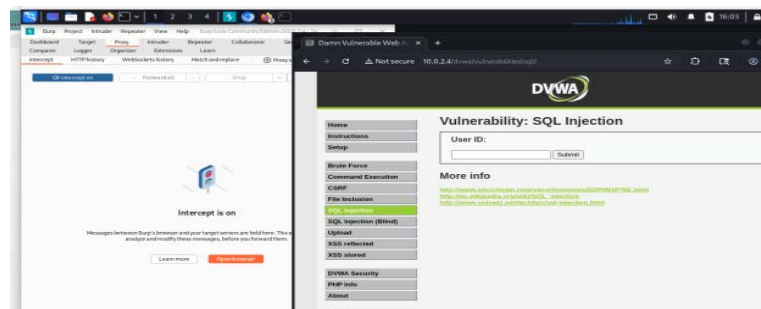
- **SQL injection**

Para realizar la tarea de realizar un ataque de SQL injection de DVWA, seguiremos estos pasos:

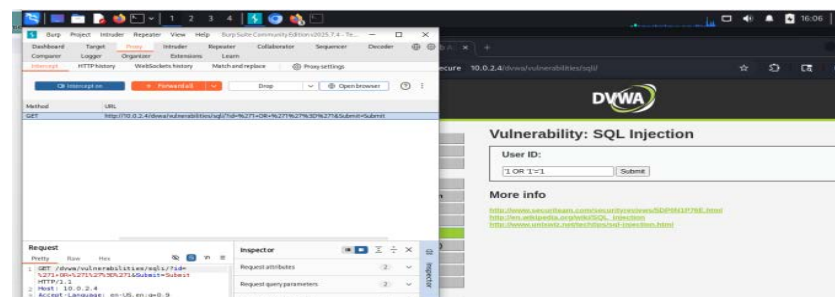
- Dentro de BurpSuite, abrimos la web de **DVWA** desde el navegador



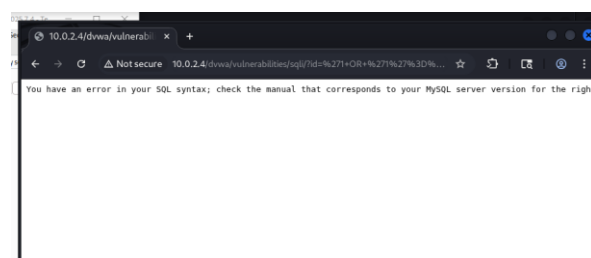
- En la WEB de DVWA accedemos al apartado **SQL injection**.



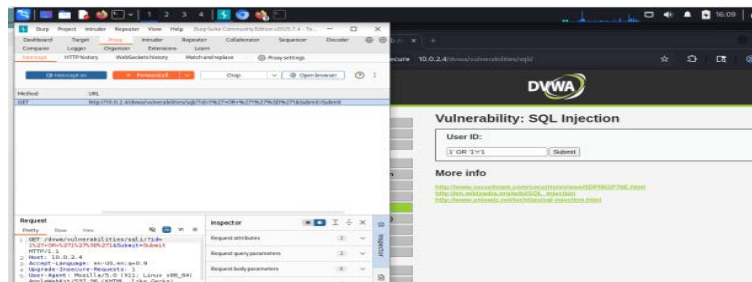
- Dentro del USER ID, vamos a probar una inyección típica de SQL Injection `1' OR '1'='1`



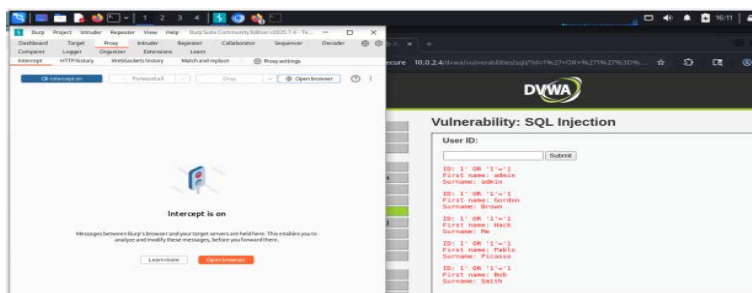
- Vemos que no hemos tenido éxito con la primera:



Modificamos la petición para escapar las comillas así:  
`1' OR '1'='1`



- Finalmente, esta petición si devuelve los datos de los usuarios de la BBDD:



## Apartado 5: Extraer datos con sqlmap

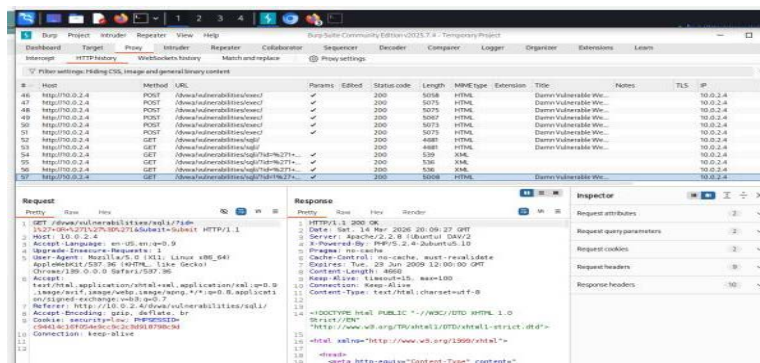
Apoyándote en la herramienta sqlmap extrae información de el "Banner de la Base de Datos" utilizando la vulnerabilidad de inyección SQL localizada en el apartado 4 en la funcionalidad "SQL injection" de Damn Vulnerable Web Application.

## Respuestas 5

- sqlmap

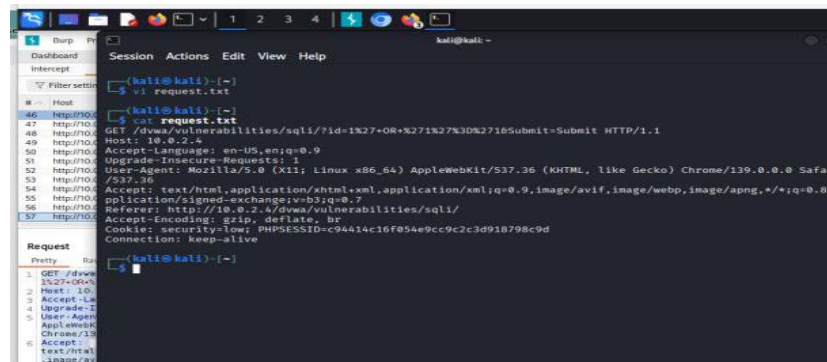
Para realizar la tareas apoyaremos en el mismo SQL injection y en la herramienta de sqlmap

- Revisamos en BurpSuite la petición interceptada del ejercicio anterior:



- Guardamos la petición en un archivo dentro de nuestro Kali





- Ejecutamos el aplicativo “sqlmap” con el request que hemos capturado:  

```
sqlmap -r request.txt --banner
```
- Finalmente nos muestra el banner solicitado:

